MODULE 4 · LECTURE 22

CS 6530 Applied Cryptography

PKI and Operational Key Management

Module 4 – Key Management, Certificates and PKI

FROM CERTIFICATE → OPERATIONS

A Certificate Is Only One Part of PKI



Public Key Infrastructure (PKI): the roles, policies, processes and systems used to manage certificates and public-key trust.

INSIGHT

Issuance is an event. PKI operation is a lifecycle.

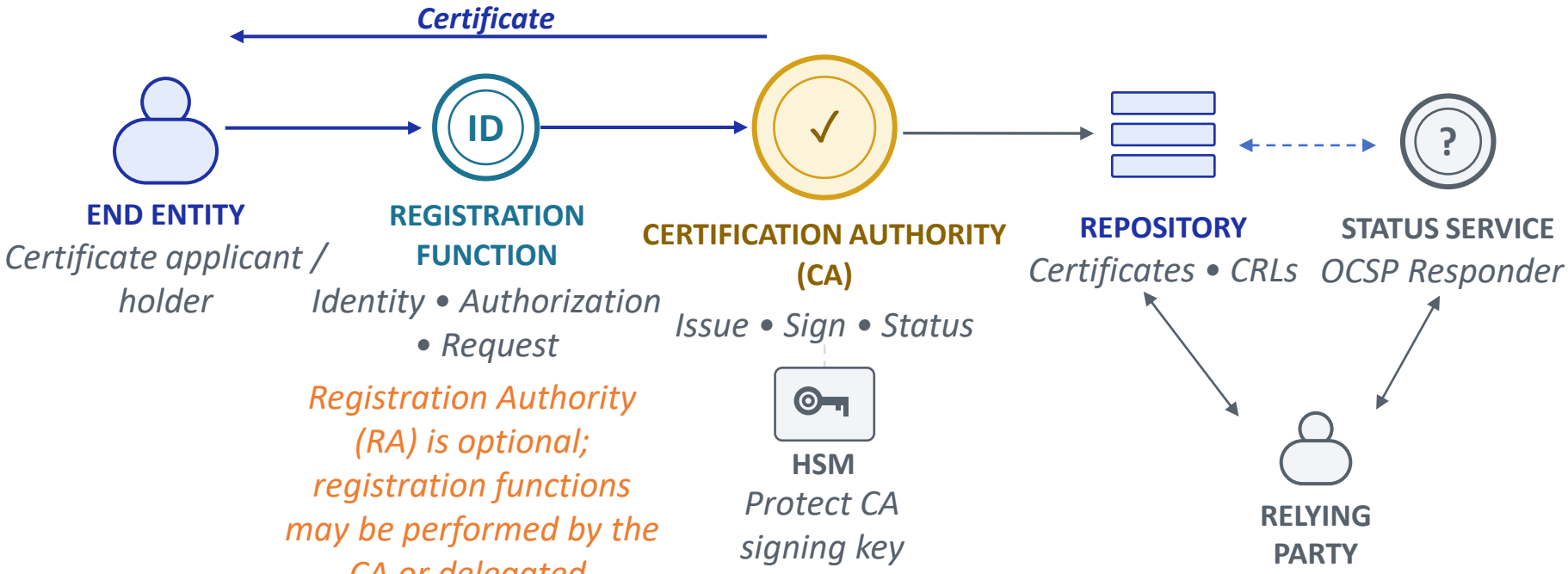
? THINK LIKE AN ENGINEER

If issuing a certificate takes seconds, what must we manage for the rest of its lifetime?

Trust must be operated throughout the certificate lifecycle.

PKI ARCHITECTURE

Who Makes Certificate-Based Trust Work?



INSIGHT

PKI combines trust roles, cryptographic keys and operational services.

? THINK LIKE AN ENGINEER

If the CA issues certificates, why does a PKI need these other components?

PKI turns a public-key binding into an operational trust service.

ROLES & RESPONSIBILITIES

Registration Verifies Identity and Authorization; Certification Creates the Credential



REGISTRATION

Establish / verify:

- Applicant identity
- Registration information
- Certificate request information
- Authorization / entitlement

Verified / authorized request information

(certificate not yet issued)



CERTIFICATION

- Apply CA policy
- Decide / authorize issuance
- Create and digitally sign certificate
- Issue certificate
- Manage certificate status

SIGNED CERTIFICATE ✓

SEPARATION OF DUTIES • LEAST PRIVILEGE • AUDITABILITY

A separate RA is not mandatory; responsibilities depend on PKI architecture and policy.

INSIGHT

The CA does not merely sign data—it issues certificates under defined policy and controls.

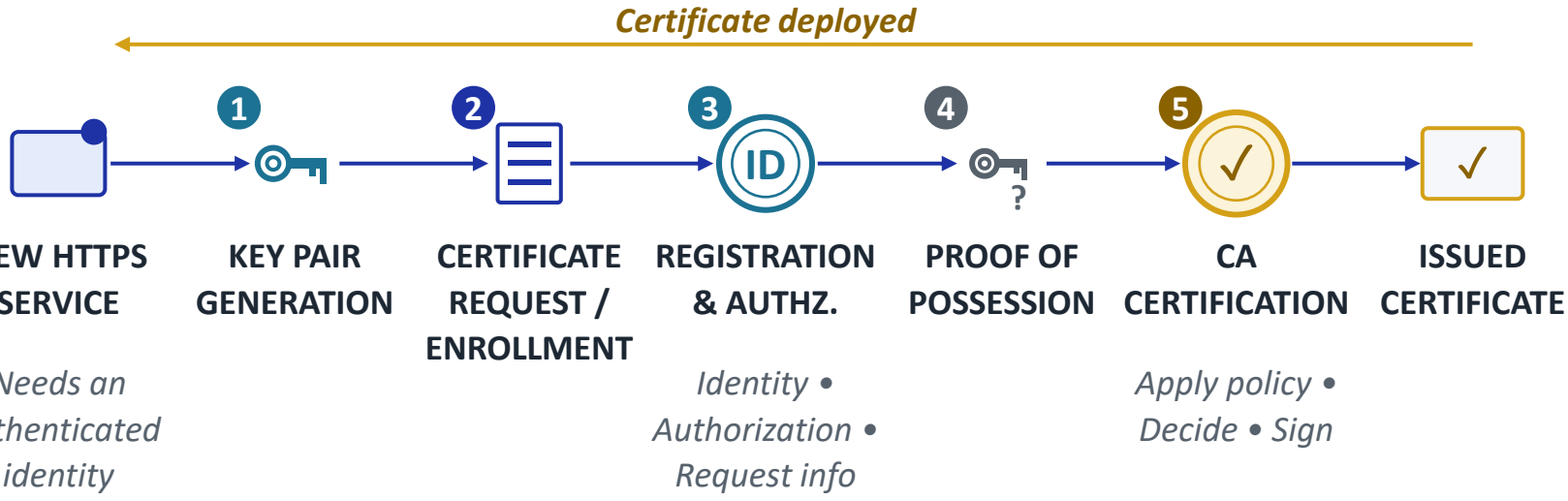
? THINK LIKE AN ENGINEER

Why might an organization separate identity verification from certificate signing?

Registration establishes confidence; certification makes the binding verifiable to relying parties.

CERTIFICATE ISSUANCE

From Engineering Need to Certificate Issuance



Registration verifies identity, authorization and request information.
Proof of Possession (PoP) demonstrates possession of the corresponding private key — **without sending the private key to the CA.**

INSIGHT

Identity verification and Proof of Possession establish different things — both matter before certification. Registration establishes who/what may be certified; PoP establishes possession of the corresponding private key

? THINK LIKE AN ENGINEER

A new HTTPS service is being deployed. At what point should its certificate and key lifecycle be planned?

Lifecycle framework: RFC 3647 • Certificate profile: RFC 5280

Plan certificate and key management as part of system design and deployment.

CERTIFICATE & KEY LIFECYCLE

Certificates and Keys Have Lifecycles

Terminology/lifecycle: RFC 3647
- *Key lifecycle: NIST SP 800-57*

TRIGGER / CONDITION	EVENT	KEY PAIR	CERTIFICATE
Certificate validity ending	**RENEWAL**	**Same** key pair	New certificate
Key replacement / cryptoperiod	**RE-KEY**	**New** key pair	New certificate
Validity period ends (Certificate ceases to be valid)	**EXPIRY**	Unchanged	No new certificate; reaches notAfter
Trust / authorization must end early	**REVOCATION**	Unchanged*	No new certificate; Status becomes revoked
Certification information needs to change	**MODIFICATION**	Same key pair	New certificate

INSIGHT-1

Does the subject/service continue?
Yes, if so: **Can the existing key continue?**
Yes → **Renewal,** No → **Re-key**
[Modify – if service & key continue, but some info modified]

Does the service no longer need another certificate?
→ let the existing certificate **expire**.
Must trust end before the scheduled expiry?
→ **revoke**.

INSIGHT-2

Renewal: "I still need the credential, and I can keep the key."
Re-key: "I still need the credential, but I cannot keep the key."
Expiry: "I no longer need another credential."
Revocation: "I cannot wait for the credential to expire."
Modification: "I still need the credential and key, but something certified about me has changed."

Certificate lifetime and key lifetime are related—but they are not the same.
Renewal, re-key, modification, expiry and revocation are different lifecycle events.

EARLY END OF CERTIFICATE VALIDITY

Revocation: More Than Key Compromise

ALREADY KNOWN — private-key compromise → REVOKE

But compromise is not the only reason.

COMPROMISE	CHANGE / REPLACE	STATUS HANDLING	OTHER
keyCompromise cACompromise aACompromise	affiliationChanged superseded cessationOfOperation privilegeWithdrawn	certificateHold removeFromCRL	unspecified

RFC 5280 §5.3.1 defines the complete enumeration; value 7 is unused.

WHO MAKES REVOCATION HAPPEN?



The CA may not know the triggering event occurred — an authorized party must report/request action per policy.

INSIGHT

Revocation requires both a technical mechanism and an operational process.

THINK LIKE AN ENGINEER

Who detects that a certificate should no longer be used—and who is responsible for revoking it?

Revocation begins with a trigger and ends when relying parties can determine the certificate's status.

CERTIFICATE STATUS

How Does a Relying Party Learn Revocation Status?

Has this certificate been revoked?



OBTAIN THE LIST AND CHECK THE SERIAL NUMBER ; *Listed → revoked. Not listed → not identified as revoked.*

ASK ABOUT THIS CERTIFICATE

ONLINE CERTIFICATE STATUS PROTOCOL (OCSP) = protocol | OCSP Responder = service



WHY OCSP? *Checks one certificate directly, without fetching a full CRL.*

OCSP Status - good ≠ certificate fully valid

Identity • validity period • certification path • purpose/policy • other checks still matter

RFC 5280 • RFC 6960

INSIGHT

Revocation status is one input to certificate validation—not the whole validation decision.

? THINK LIKE AN ENGINEER

OCSP returns good. Is the certificate therefore acceptable? Why or why not?

CRLs publish revocation information; OCSP provides online certificate-status responses.

PKI IN PRACTICE

Web PKI and Internal PKI — Same Foundations, Different Trust Domains

WEB PKI	SHARED PKI FOUNDATIONS	INTERNAL / PRIVATE PKI
Public Website	**X.509 Certificates**	Internal Service / Device / User
Publicly Trusted Issuing CA	**CA Chains**	Enterprise Issuing CA
Public Root CA	**Trust Anchors**	Enterprise Root CA
Browser / OS Root Program	**Certificate Validation**	Organization-Managed Trust Store
Public CA ecosystem *Browser / OS trust stores*	**Lifecycle & Revocation**	*Organization-controlled CA(s)* *Organization-defined policy*

Same cryptographic trust foundations

CERTIFICATE TRANSPARENCY (CT) Log

What certificates are being publicly issued?

Publicly observable, auditable issuance — it does not itself prevent mis-issuance.

Certificate choice follows the relying parties and their trust anchors — not simply whether the server is physically "inside" or "outside."

INSIGHT

Web PKI adds Internet-scale governance and transparency to the certificate-chain model.

? THINK LIKE AN ENGINEER

A service must be accessed by both Internet users and internal enterprise systems. What certificate(s) and trust model would you use? Why?

RFC 5280 • RFC 9162 • CA/Browser Forum • ***Smallstep — Everything PKI***

The same X.509 foundations support different PKI ecosystems; trust depends on the relying policy.

KEY PROTECTION & MANAGEMENT

How Are PKI Private Keys Protected and Managed?

PROTECT / STORE / USE



Software Key Store | Hardware Token | HSM

Choice depends on role and assurance — not every key needs an HSM.

KMS — Key Management System
CKMS — Cryptographic Key Management System

SOFTWARE KEY STORE

Key protected in software / OS / application environment

HARDWARE TOKEN

Key protected in a dedicated user/device hardware token

HSM — Hardware Security Module

Keys protected and cryptographic operations performed in dedicated security hardware

MANAGE THE KEY LIFECYCLE (Depends on system architecture)

GENERATE→STORE→ACTIVATE→CONTROL→ROTATE→DEACTIVATE→DESTROY

KMS/CKMS manages the key lifecycle, including backup and audit.

PKI / CERTIFICATE TRUST

ENROLLMENT→ISSUANCE→DEPLOYMENT→RENEW→REVOKE/STATUS

PKI manages certificates and certificate-based trust.

DON'T CONFUSE THE ROLES

Key Store → protects keys • KMS → manages lifecycle • PKI→ manages trust

Subject key compromised → affects one identity or service.

CA key compromised → affects many certificates and relying parties.

INSIGHT

Key protection must match the key's role, lifecycle stage and impact of compromise.

? THINK LIKE AN ENGINEER

A subject key and a CA signing key both need protection. Should it differ, and why?

NIST SP 800-57 • NIST SP 800-130 • FIPS 140-3

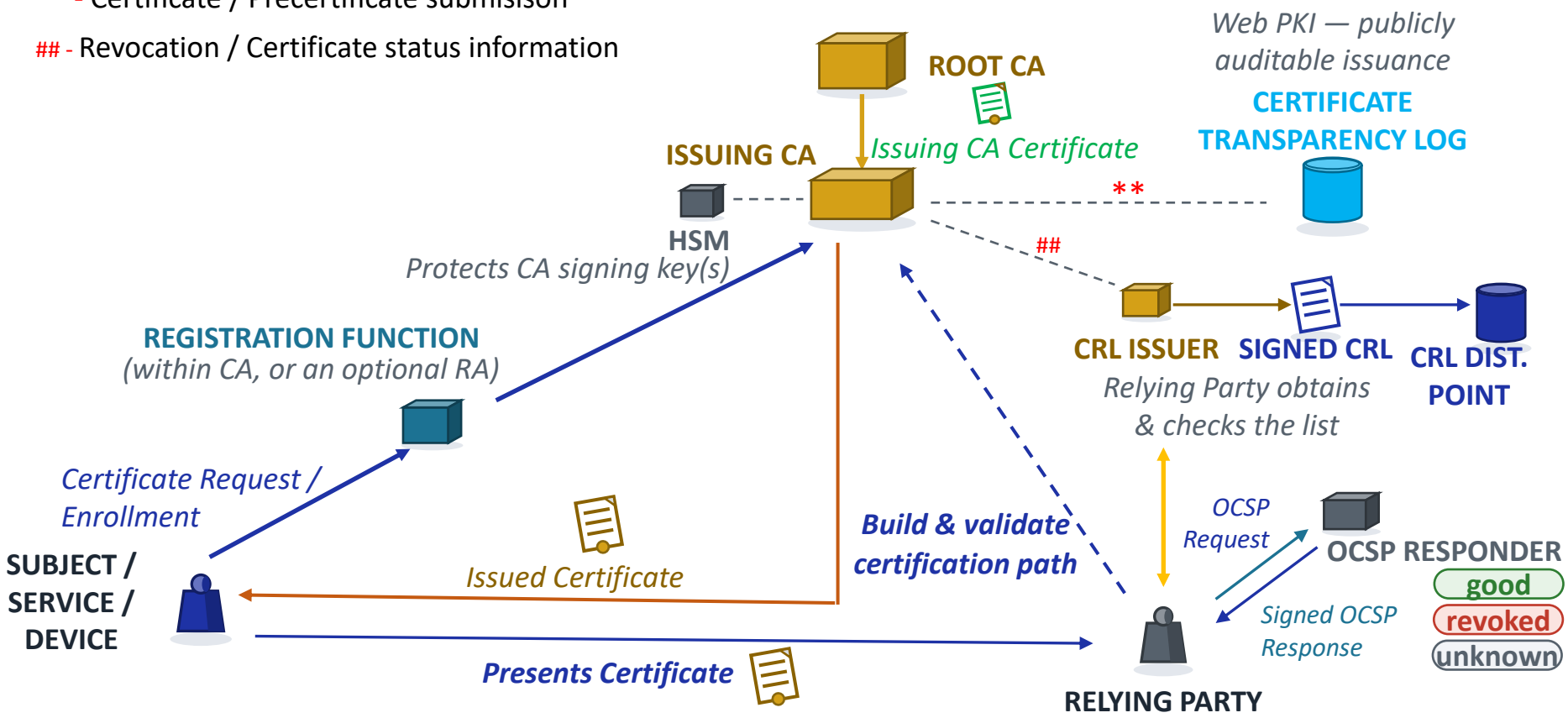
PKI trust depends not only on certificates but also on secure key storage and lifecycle management.

PUTTING IT ALL TOGETHER

PKI Operations — Build the Reflexes

** - Certificate / Precertificate submisison

- Revocation / Certificate status information



THINK LIKE AN ENGINEER — FIVE PKI REFLEXES

① IDENTITY ② TRUST ③ STATUS ④ KEYS ⑤ LIFECYCLE

INSIGHT *Effective PKI operation brings identity, trust, status, key management and lifecycle management together*

Certificate-based trust is a system — not a document.

STANDARDS & FURTHER READING

References

1 — PKI & CERTIFICATES

RFC 5280
Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile

RFC 3647
Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework

2 — CERTIFICATE STATUS & TRANSPARENCY

RFC 6960
X.509 Internet Public Key Infrastructure Online Certificate Status Protocol — OCSP

RFC 9162
Certificate Transparency Version 2.0

3 — KEY MANAGEMENT & PROTECTION

NIST SP 800-57 Part 1
Recommendation for Key Management: General

NIST SP 800-57 Part 2
Best Practices for Key Management Organizations

NIST SP 800-130
A Framework for Designing Cryptographic Key Management Systems

FIPS 140-3
Security Requirements for Cryptographic Modules

4 — WEB PKI & APPLIED READING

CA/Browser Forum
Baseline Requirements / Web PKI ecosystem

Smallstep — Everything PKI
Everything you should know about certificates and PKI but are too afraid to ask.

NEXT → CERTIFICATE MANAGEMENT PROTOCOLS
CMP • EST • ACME